Projeto OFX — Explicação da API

Aluno: Henrique Molinari
RA: 25001176

O que é

A API é o "cérebro" de um mini ERP financeiro. Ela recebe extratos bancários no formato OFX (o arquivo que o banco gera), guarda as movimentações em um banco PostgreSQL e permite classificar, comentar, analisar e exportar esses dados. Foi feita em Node.js com Express.

A ideia

Em uma empresa, quem mexe com os dados financeiros não tem todos o mesmo papel. Por isso a API foi pensada para três tipos de usuário, cada um enxergando e fazendo só o que precisa:

- **Analista fiscal:** analisa, altera as contas, classifica e faz comentários. Também importa dados, vê os gráficos e tira relatórios.
- **Estagiário:** lança dados (importa o OFX ou digita uma conta), mas tem poucos acessos. Não vê gráficos, não tira relatório e não altera contas.
- **Gestor (head):** acompanha os gráficos, lê os comentários, pede balanços e delega tarefas para a equipe. Não precisa importar nem alterar contas.

O que a API oferece

- **Autenticação:** login, renovação de sessão e logout
- **Usuários:** cadastro da equipe (só o gestor)
- **Importação:** lê o arquivo OFX, mostra uma prévia e grava no banco, ignorando contas duplicadas
- **Tratamento:** lista, lança, altera e classifica as contas em categorias (de forma manual ou automática)
- **Comentários:** o analista registra observações em cada conta
- **Análise:** totais de entradas e saídas, gastos por categoria e evolução do saldo
- **Exportação:** baixa os dados em CSV, Excel, TXT ou OFX
- **Tarefas:** o gestor delega pedidos (ex.: "preciso do balanço de setembro")

Autenticação x Autorização

São duas etapas diferentes, e a API trata cada uma separadamente:

Autenticação = "Quem é você?"
É o login. A pessoa prova quem é com e-mail e senha e recebe um token. Se não estiver identificada, a API responde erro 401. Exemplo: "Sou a Ana, aqui está minha senha." → o sistema confirma que ela é a Ana.

Autorização = "O que você pode fazer?"
Depois de saber quem é, a API confere se o perfil dela tem permissão para aquela ação. Se não tiver, responde erro 403. Exemplo: o Henrique (estagiário) já está logado, mas ao tentar abrir os gráficos recebe "sem permissão", porque estagiário não vê gráficos.

> Resumindo: autenticação é a portaria do prédio (provar quem é), autorização é a chave de cada sala (o que cada um pode abrir).

Como foi testado

- Testes automatizados no backend (unitários e de integração)
- Coleção do Insomnia com 78 requisições e testes, separadas por perfil, incluindo os casos em que o acesso deve ser negado (erro 403)

Organização do projeto

Pasta	Conteúdo
`bd/`	scripts SQL do banco
`backend/`	código da API, uma pasta por módulo
`api/`	documentação das rotas e coleção do Insomnia
`env/`	variáveis de ambiente (configurações e segredos)
`frontend/`	telas em React que consomem a API
`diagrama/`	diagrama de classes e DER